Security Auditing

Lesson#10

Scaling the Investigation

Enterprise Forensics, Remote Triage & Forensics-by-Design

School Year 2025/2026

Master in Informatics Security (MSI) / Master in Informatics Engineering (MEI)

Informatics Engineering Department

University of Coimbra

Presentation Agenda

Module 1: The Enterprise Crisis

Limits of traditional forensics and the scale problem.

Module 2: Advanced Triage

Frameworks for speed: KAPE and Velociraptor.

Module 3: Infrastructure Forensics

The network witness, virtualization, and exfiltration.

Module 4: Memory Forensics at Scale

MemProcFS and remote acquisition strategies.

Module 5: Readiness & Compliance

NIS2, DORA, and the “Expert Witness” Audit.

Part 1

The Enterprise Crisis

Limits of traditional forensics and the challenge of scale

Audit vs. Forensic Investigation

The Auditor

Focuses on Compliance. Verifies if controls exist and are designed correctly (e.g., ISO27001).

"Do you have an NTP policy?"

The Investigator

Focuses on Truth. Reconstructs events using low-level artifacts.

"Why did machine A talk to B at 02:00?"

The Enterprise Scale Problem

Modern environments are no longer single-workstation scenarios. Investigators face:

- 1,000+ endpoints across global offices.
- Hybrid cloud infrastructure (AWS/Azure/On-Premise/...).
- Encryption everywhere (TLS 1.3, BitLocker...).
- Ephemeral assets (Containers, Serverless Computing).

Traditional "image everything" forensics is becoming impossible (except in very specific scenarios).

Image source: https://www.forensicfocus.com/stable/wp-content/uploads/2025/03/network-forensics-1024x574.png

The "Dead Box" Fallacy

Why pulling plugs and imaging disks doesn't work at scale

Traditional "Seize & Image"

High friction for business operations.

Massive storage requirements

(2TB drive = 2TB image).

Misses volatile data (RAM, network states).

Modern Triage Approach

Low friction: agents collect artifacts remotely.

Fast: collection in < 10 minutes.

Targeted: only collect high-value artifacts

(e.g. NTFS $MFT, Registry…).

Remember our VelocityCap Case Study?

€1.2M

LOST IN 15 MINUTES

Why did they fail?

The system was **not** forensically ready. The admin rebooted the server, purging 100% of the volatile RAM evidence before investigators arrived.

Lack of NTP led to a 125-second clock drift, making log correlation legally inadmissible.

Part 2

Advanced Triage Frameworks

KAPE, Velociraptor, and the scale economy

The Modern Triage Concept

Collecting what matters, fast

“Collector” Methodology

Instead of copying a whole disk, we target the “Golden Artifacts” that contain 90% of the forensic story.

A triage agent executes a **Target** (list of files to grab) and a **Module** (tool to process them on-the-fly).

Collected Artifacts: $MFT, Prefetch, Registry, Event Logs, Web History…

$MFT is a hidden system file in Windows NTFS, that tracks all that information about the files on your system, including their physical locations on the disk, timestamps, names, sizes, etc. It's literally the most important file on your computer. It's what defines a “file” vs. random data on the drive.

Other file systems have similar files or block structures.

Speed vs. Depth

Balancing system availability with evidentiary integrity

Triage allows investigating the entire fleet of servers and desktops before the attacker completes his objective.

KAPE: Artifact Parser & Extractor

Target-Module Synergy

Typical targets:

- filesystem metadata, event logs, registry hives, ...
- KAPE finds them and copies them while maintaining timestamps (using Raw Disk Access).

Modules (the “executors”):

- KAPE runs external tools (for instance Hayabusa or RegRipper) against the targets to create CSV/JSON reports.

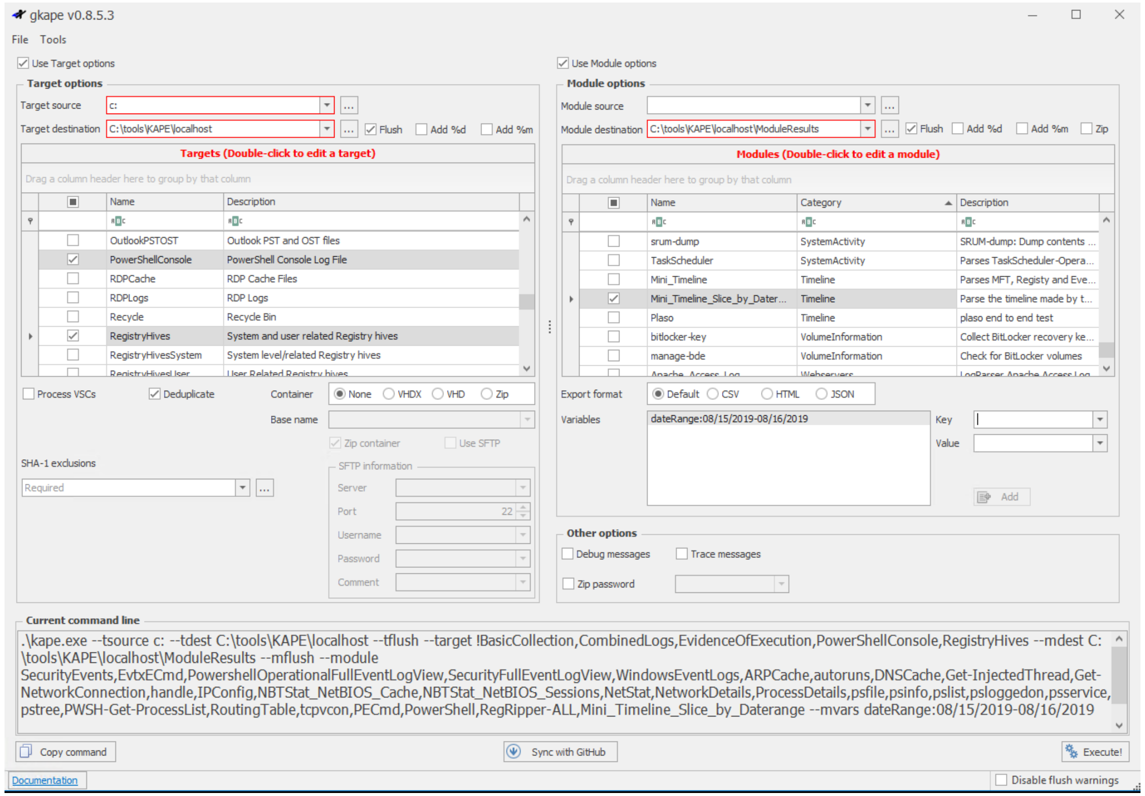


Image source: https://holisticinfosec.io/post/140/gkape.PNG

The KAPE Workflow

Identify

Select Targets
(e.g., Windows .LNK files,
ChromeHistory)

Extract

Raw Disk Access
copies locked files

Process

Modules parse data into
scannable formats

Critical Triage Artifacts

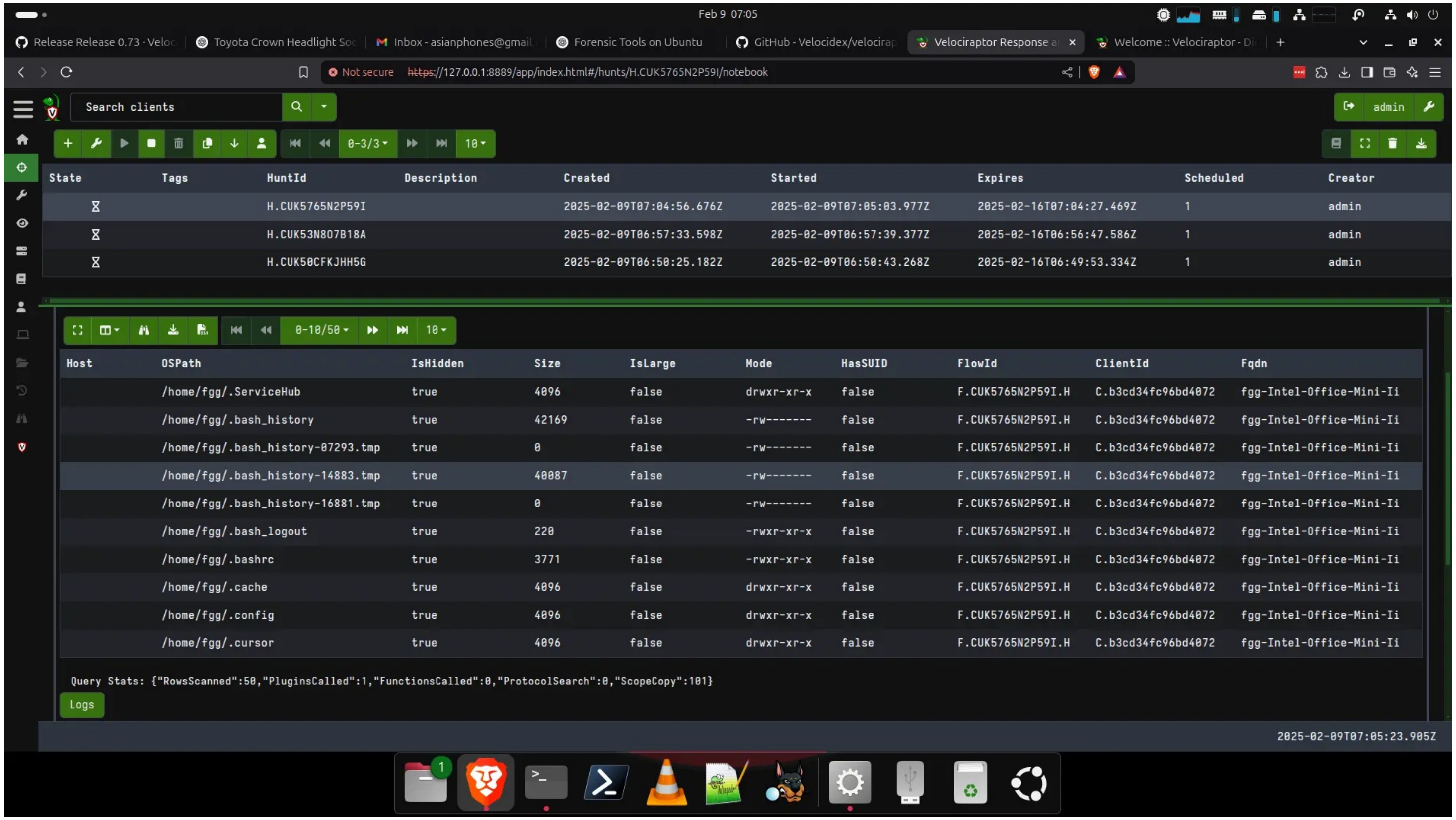
The example of Windows Servers

- **$MFT:** NTFS Master File Table. The ultimate timeline of file creation/deletion.
- **Prefetch:** Records which applications were executed and when.
- **Registry Hives:** SYSTEM, SOFTWARE, SAM, and NTUSER.dat (User persistence).
- **Event Logs:** Usually focused on Security (4624) and PowerShell (4104).
- **LNK files:** automatically track user activity, providing evidence of file access, even after the target file is deleted, moved, or accessed from removable media.

Velociraptor: the Scaling King

Visibility as a Service

- Velociraptor uses an **Agent-Server** model.
- Instead of pushing tools, we **push queries**.
- Allows an investigator to ask: “*Show me all machines that have a process running from \Temp*” across 1,000 machines



[Imge source: https://sqfr.uk/wp-content/uploads/velociraptor-gui-brave-incident.webp](https://sqfr.uk/wp-content/uploads/velociraptor-gui-brave-incident.webp)

VQL: Velociraptor Query Language

Treating the infrastructure as a database

```
SELECT Name, CommandLine, Exe
FROM pslist()
WHERE Exe =~ 'powershell.exe'
AND CommandLine =~ '-enc'
```

Infrastructure as a Database

VQL allows treating endpoints like SQL tables:
You don’t “scan”; you “query”.

Queries are extremely lightweight, preventing the “agent-bloat” that crashes systems.

The Power of Velociraptor’s Hunt

running a ”collection hunt" across hundreds of machines in minutes

10k+
ENDPOINTS INVESTIGATED

15m
TOTAL COLLECTION TIME

This is "Forensic Readiness" in action.

By the time an auditor arrives, the data is already centralized.

Kape vs. Velociraptor

Feature	KAPE	Velociraptor
Architecture	Ad-hoc / Tool-based	Agent-Server / Query-based
Speed	Extremely fast per-host	Near-instant across fleet
Analysis	Requires external viewers	Built-in dashboard & VQL
Best For	Deep dive on single host	Live hunting & Triage

Legal Integrity in Automated Triage

The Digital Paper Trail:

- Every collection must be hashed (e.g. SHA-256).
- If the triage tool doesn't hash the output, the evidence is a "Self-Service" claim.

Rule:

- The triage server must be immutable and audit-logged to prove no investigator tampered with the results.

MathML representation of Integrity:

$$H(\text{Evidence}_{\text{Original}}) = H(\text{Evidence}_{\text{Copy}})$$

Part 3

Infrastructure & Networking

The wire (almost) never lies

{side note:} Blinding the Host Forensics

Anti-forensics at scale

The Observer Effect reversed:

- Attackers no longer just “hide” – they sabotage the observer (your forensics tools).
- If the agent is compromised, the audit trail becomes a curated fiction.

The Blindside technique (EDR/Triage Silencing):

- bypassing “Userland Hooking” via Direct Syscalls.
- the agent reports “Healthy” while malicious code runs invisible to hooks.

The BYOVD (Bring Your Own Vulnerable Driver) technique:

- Attackers drop a signed, vulnerable driver to gain Kernel Privileges.
- The Kill-Switch: used to terminate “Protected Processes” of triage agents (Velociraptor, EDR, KAPE).

The auditor’s challenge (*Who Audits the Auditor?*):

- Verification: cross-reference Endpoint Triage with the Network Witness.
- Resilience: forensic readiness requires tamper-protected agents.

The Network as a Silent Witness

Beyond the Endpoint

Network evidence pillars:

- Endpoints can lie (malware hiding processes), but the network is harder to deceive.
- **NetFlow**:
  - the ”phone bill" of forensics.
  - metadata (source/destination IP addresses, source/destination ports, protocol type, ingress interface, and Type of Service (ToS))
- **PCAP**:
  - the “tape recording”.
  - every packet, every byte.

Netflow vs. Full Packet Capture (PCAP)

NetFlow (metadata)

Low storage cost.

Retain for 12+ months.

Excellent for tracing Command & Control (C2) patterns over time.

PCAP (full packets)

Extreme storage cost.

Retain for days/weeks.

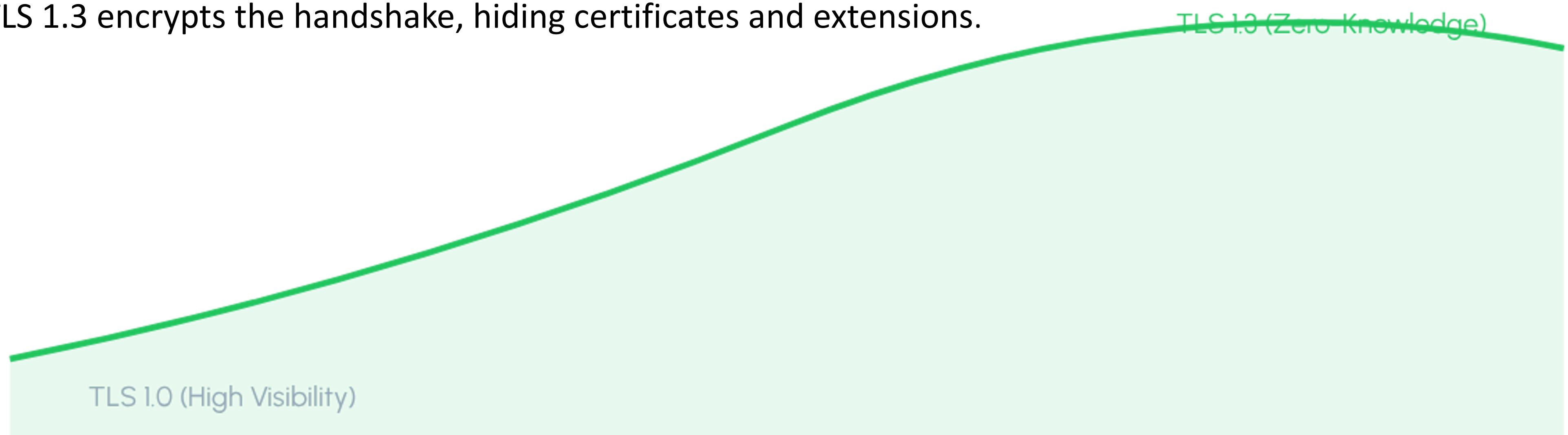
Essential for carving payloads and inspecting encrypted handshakes.

The Challenge of TLS1.3

Why forensics don’t like encrypted traffic

Network visibility is decreasing as encryption matures.

TLS 1.3 encrypts the handshake, hiding certificates and extensions.



Workaround: focus on Endpoint-based network visibility (e.g., netstat from RAM) where data is decrypted.

Virtualization

The Time Machine

Snapshots as Frozen State

- In a virtualized environment (vSphere/Hyper-V), a snapshot is a Gold Mine. It captures the entire disk and RAM (if selected) in a point-in-time.

Forensic Readiness Tip:

- Automate snapshots upon high-severity SIEM alerts.

Investigation benefit: Replay the malware's actions in a sandbox without altering the original system.

Cloud Snapshot Forensics (AWS/Azure)

Scaling to the "No-Touch" investigation

The Virtualization Advantage :

- Use Cloud APIs to "freeze" state without touching the Guest OS.
- Snapshots capture the entire Elastic Block Store (EBS) or Managed Disk at a specific point in time, including deleted files and unallocated space.

The workflow:

1. Snapshot: create a point-in-time snapshot of the suspected volume.
2. Exfiltration/Cloning: convert the snapshot to a new volume in a dedicated, isolated Forensic VPC/VNet.
3. Attach the volume to a "Forensic Workstation" (clean VM) as a secondary disk.

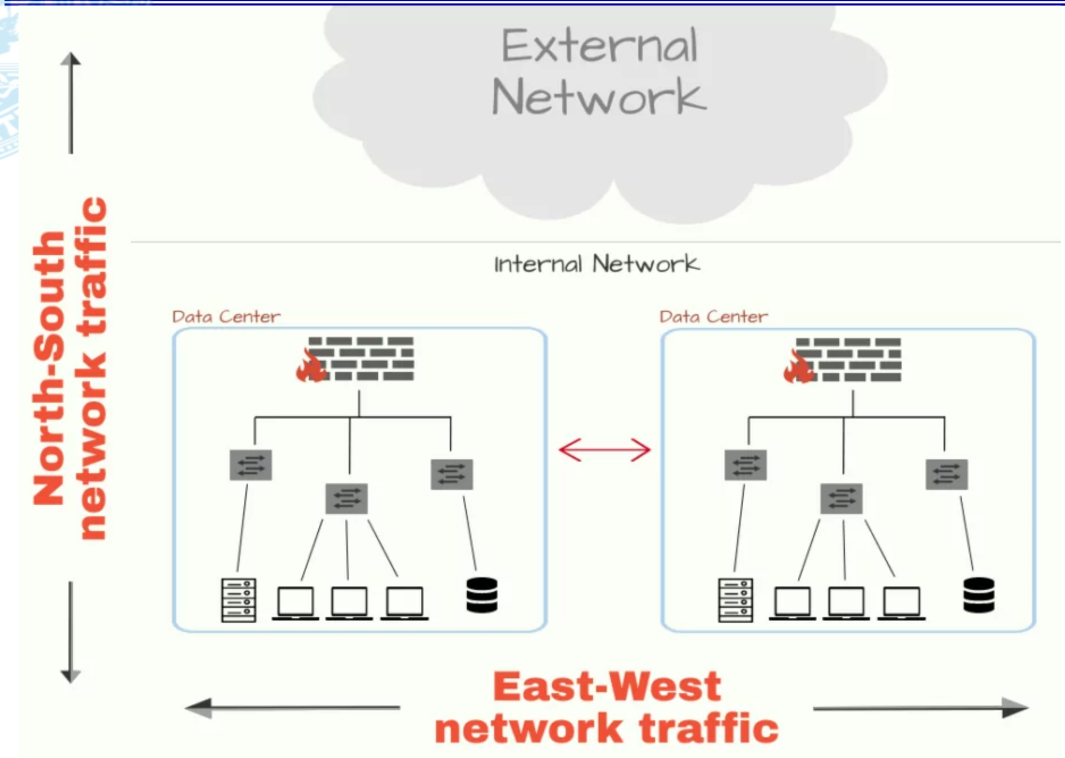
Zero downtime (on the production environment); zero "Observer Effect" (on the snapshot disk).

Auditing the Evidence (DORA & NIS2 Alignment):

- Immutable Custody: use AWS S3 Object Lock or Azure Immutable Blob Storage to store images.
- Log Integrity: CloudTrail/Activity Logs provide an implicit, automated "Chain of Custody".
- Compliance: proves "Due Care" by showing the ability to perform root-cause analysis without contaminating the crime scene.

The East-West Traffic Visibility Crisis

Catching lateral movement



Lateral Movement

The attacker's horizontal movement between servers (East-West) often bypasses perimeter firewalls.

Without vTAP or Micro-segmentation logs, this traffic is invisible.

This was the failure in the VelocityCap Use Case scenario: they saw the entry, but not the internal pivot.

Image source: https://socradar.io/wp-content/uploads/2020/09/my-visual_48541384-1024x683.png.webp

Log Aggregation
Forensic Data Lake

SIEM (Detection)

Designed for real-time alerting.

Often deletes logs after 30-90 days to save costs.

Forensic Data Lake (Retention)

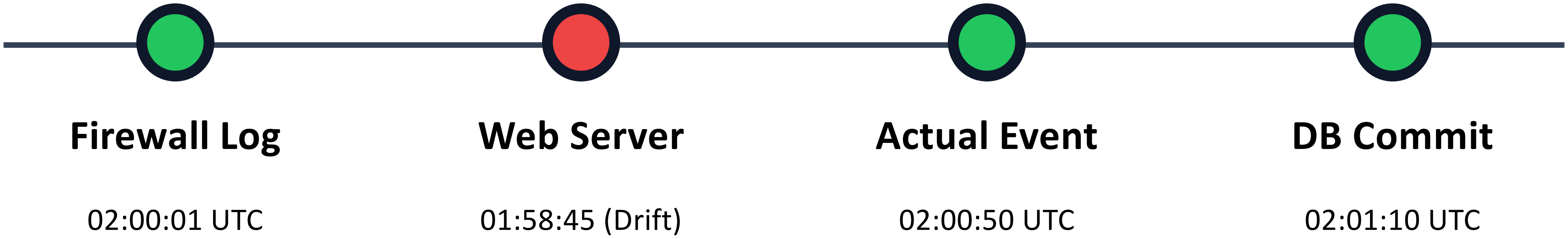
Designed for investigations.

Stores raw, compressed, hashed logs for 1-2 years. Essential for NIS2/DORA.

The Pillar of Time: NTP Sync

The critical role of a ”Common Clock”

(recall VelocityCap drift?)



Without NTP synchronization, the causality between an entry and a theft is legally contested.

Lateral Movement Indicators
(for instance, in the case of Windows ecosystems)

WMI (Windows Management Instrumentation):

– Used for remote code execution.

– Monitor for Event ID 5858 (WMI-Activity log, indicates that a WMI query failed, typically due to inefficient, blocked, or timed-out queries).

– Also monitor for Event ID 5861 (WMI Permanent Event Consumer), an indicator of persistence.

RDP (Remote Desktop):

– Unusual logins from internal IPs to sensitive servers (Event ID 4624, Logon Type 10). *curious about this event? Check here:* *https://www.ultimatewindowssecurity.com/securitylog/encyclopedia/event.aspx?eventid=4624*

PowerShell Remoting:

– Check for “Invoke-Command” or “Enter-PSSession” in ScriptBlock logs.

SMB Shares:

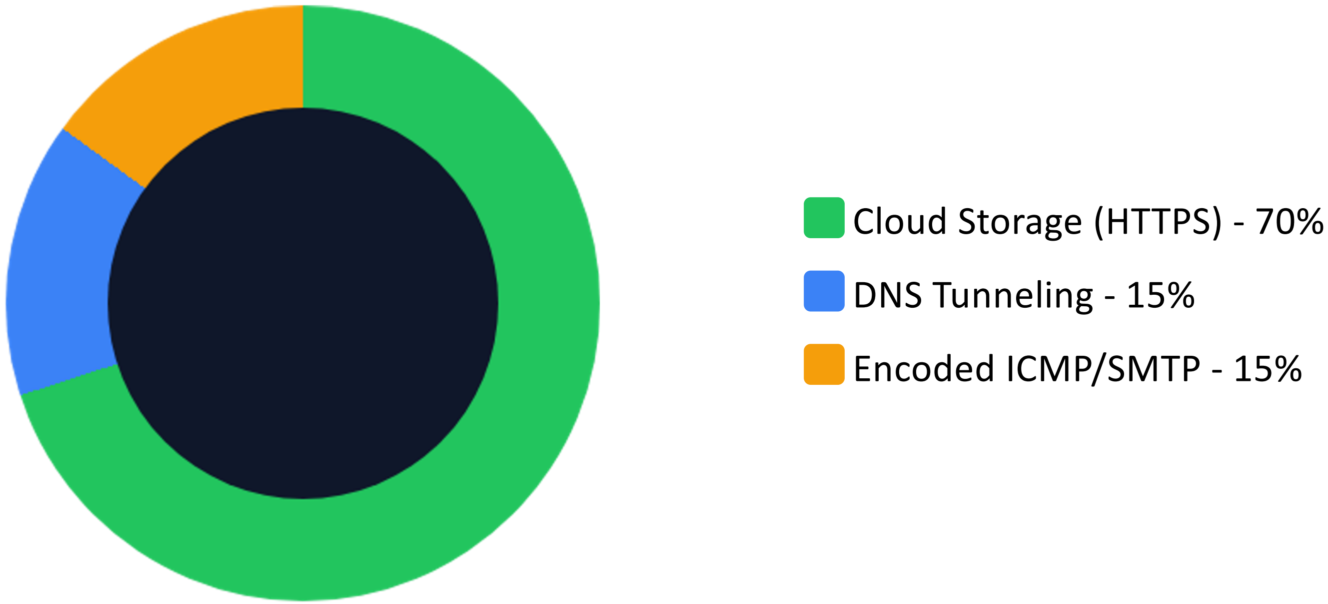
– Mounting the C$ share of a neighbor server (Admin$ access).

Suggested reading about Windows logging:

– Logs You Don’t Collect – The Evidence You’ll Wish You Had

Exfiltration Detection Patterns

DNS tunnelling, Cloud Storage uploads, botnet C&C...



Investigators look both for *beaconing* (regular small packets) and *large outbound spikes*.

Still remember about exfiltration using DNS from “Infraestruturas Seguras”?

Part 4

Memory Forensics at Scale

Exploring the Live State

Evolution of Memory Forensics

Moving beyond Volatility3 command line

2010s
Volatility 2.0
Manual Profiles

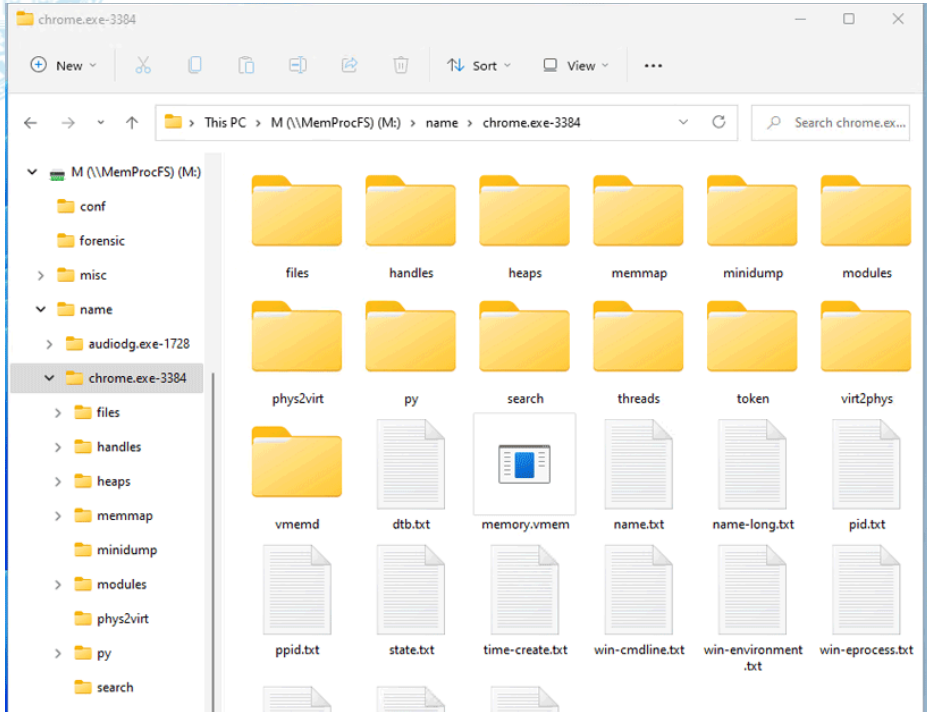
2020
Volatility 3.0
Symbol-Driven

2023
MemProcFS
Memory-as-Disk

Now
Live Triage
Cloud Enclaves

MemProcFS: Memory as a Drive *(recall from last week)*

Memory as a Virtual File System



No More Command Line?

MemProcFS mounts a RAM image as a **Virtual Drive** (**M:**).

You can use Windows Explorer to browse 'M:\sys\proc' and see memory artifacts as folders.

Enables using standard tools (AV scanners, strings) directly on the memory dump.

The Benefits of “Mounter” Analysis

Browsing RAM like a hard drive

Speed

Instant access to registry hives and file handles without parsing.

Timeline

Built-in timeline view (`M:\sys\timeline.csv`) for rapid event correlation.

Networking

View all active sockets as a simple text file under `M:\sys\net`.

Hunting Fileless Malware

No debuggers needed

Indicators of Injection

Process with RWX memory segments (Read/Write/Execute).

Memory segments not backed by a file on disk.

MZ headers found in *explorer.exe* heap.

The "Malfind" Plugin

Automatically flags injected code.

This is the "Smoking Gun" that standard antivirus and disk-only forensics will miss most of the time.

RWX (Read-Write-Execute) memory segments are memory regions within a process's address space that allow code to be read, modified, and executed simultaneously. While necessary for specific legitimate tasks like JIT (Just-In-Time) compilation, they pose a major security risk, as they enable attackers to write malicious shellcode and immediately run it.

Finding MZ headers (*\0x4D5A*) in little-endian (ASCII "MZ") in the heap of *explorer.exe* is a common indicator in memory forensics that a Portable Executable (PE) file (such as a DLL, EXE, or driver) has been loaded, mapped, or injected into that process's memory space.

Timeline Analysis in RAM

The history underneath

Memory isn't just “Current State”; it contains history.

What can we can carve?

User Artifacts

Recent CLI commands typed in cmd.exe/powershell

Decrypted browser URLs stored in RAM buffers.

…

Process Artifacts

Creation and termination times of processes.

Open File Handles
(“What was the attacker reading?”).

…

Risks of Remote Acquisition

System stability at risk...

Imaging 128GB of RAM over a 1Gbps network takes ~17 minutes.

During this time:

- The target machine may experience "Lag."
- The acquisition tool occupies kernel space, potentially causing a BSOD (Blue Screen).

The Observer Effect:

- The act of collecting RAM changes the RAM.
- For instance, the triage agent itself (e.g. Velociraptor) will occupy memory pages, potentially overwriting small pieces of evidence like shellcode in unallocated space.
- The memory image is a “smear”, not a perfect snapshot.

Part 5

Readiness & Compliance

Governance for the Post-Mortem Audit

Forensic-by-Design Architecture

Building blocks

Immutable Logs

WORM (Write Once, Read Many) storage to prevent attackers from clearing their tracks.

Sub-Second Sync

NTP across every server, VM, and container. No drift allowed.

Legal Mandate

HR banners and contracts that authorize “Right to Monitor” and forensic collection.

NIS2 & DORA Compliance

The “Duty to Investigate”

NIS2 Directive

Article 21 Due Care – requires incident handling and risk management.

If you can’t investigate, you are “Cyber-Negligent”.

Due Care means proving a dedicated effort toward security measures. From a forensic perspective, an auditor will check:

- Is there an Evidence Preservation policy?
- Are first responders trained to NOT reboot systems?
- Is the 24/72-hour reporting based on evidence or "Guesswork"?

DORA regulations

Article 13: post-incident reviews must include "Forensic Analysis" for major ICT disruptions in the financial sector.

“Financial entities shall determine... the quality and speed of performing a forensic analysis, where deemed appropriate.”
(Article 13, Clause 2(b))

Does the organization have a pre-approved legal contract with an external “Retainer” for deep-dive forensics? DORA implies that “speed of performing analysis” is a metric for compliance.

Q&A

Readiness Checklist

Centralized, immutable logging?

NTP Sync verified across fleet?

Triage agent (Velociraptor) deployed?

First Responders trained in RAM capture?

?

Ready for the Lab Session?